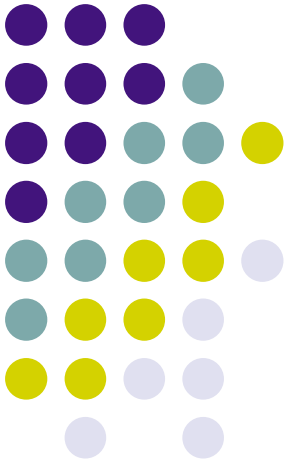


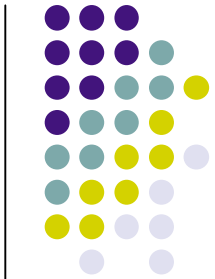


Securing Apache

Daniel López Ridruejo
daniel@rawbyte.com

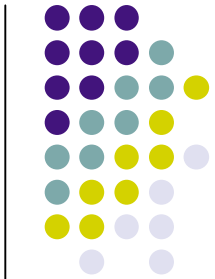


About me



- Open source: Author of mod_mono, Comanche, several Linux Howtos and the Teach Yourself Apache 2 book
- Company: founder of BitRock, multiplatform installers and management software

About this presentation

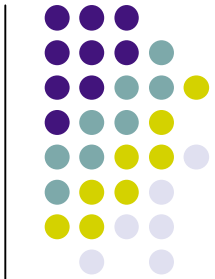


Overview of different ways to secure Apache

- Configuration
- Third-party modules
- Isolation
- Secure gateway

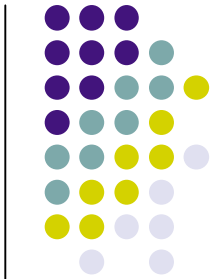
For detailed configuration information, check the companion PDF article

Know your server



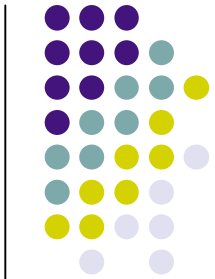
- Built-in and loadable modules
- Disable any unused modules
  - SSL, Server Side Includes, CGI, etc.
  - Dynamic content : PHP, mod_perl
- Remove default examples and demos

Locking Down the Server



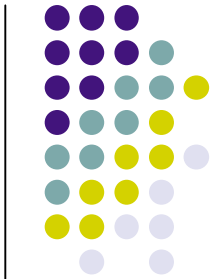
- Directory listings
- Files not intended for publishing
- Restricting program execution
- Preventing configuration changes
- Server information

Access control



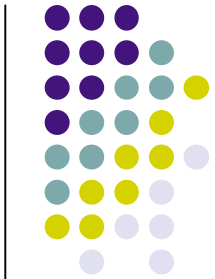
- Who can have access to what content in your server
- Based on:
  - Password: mod_auth, mod_auth_dbm
  - SSL certificates
  - Where it is coming from: mod_access
  - Other client attributes
- Authentication/Authorization mixed, Apache 2.1 offers better separation

Access control



- Basic and Digest
  - Client issues request
  - Server checks user name and password provided, otherwise 401 HTTP response
  - Prompt user, retry request
- Create user database, configure server globally or per location
- Form based authentication

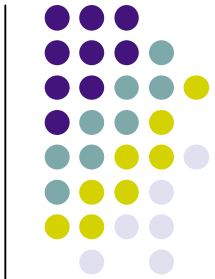
Access control



- mod_access provides restriction based on IP address range, hostname and environment variables
- <Limit> <LimitExcept> allows enabling or disabling specific methods (useful for DAV)

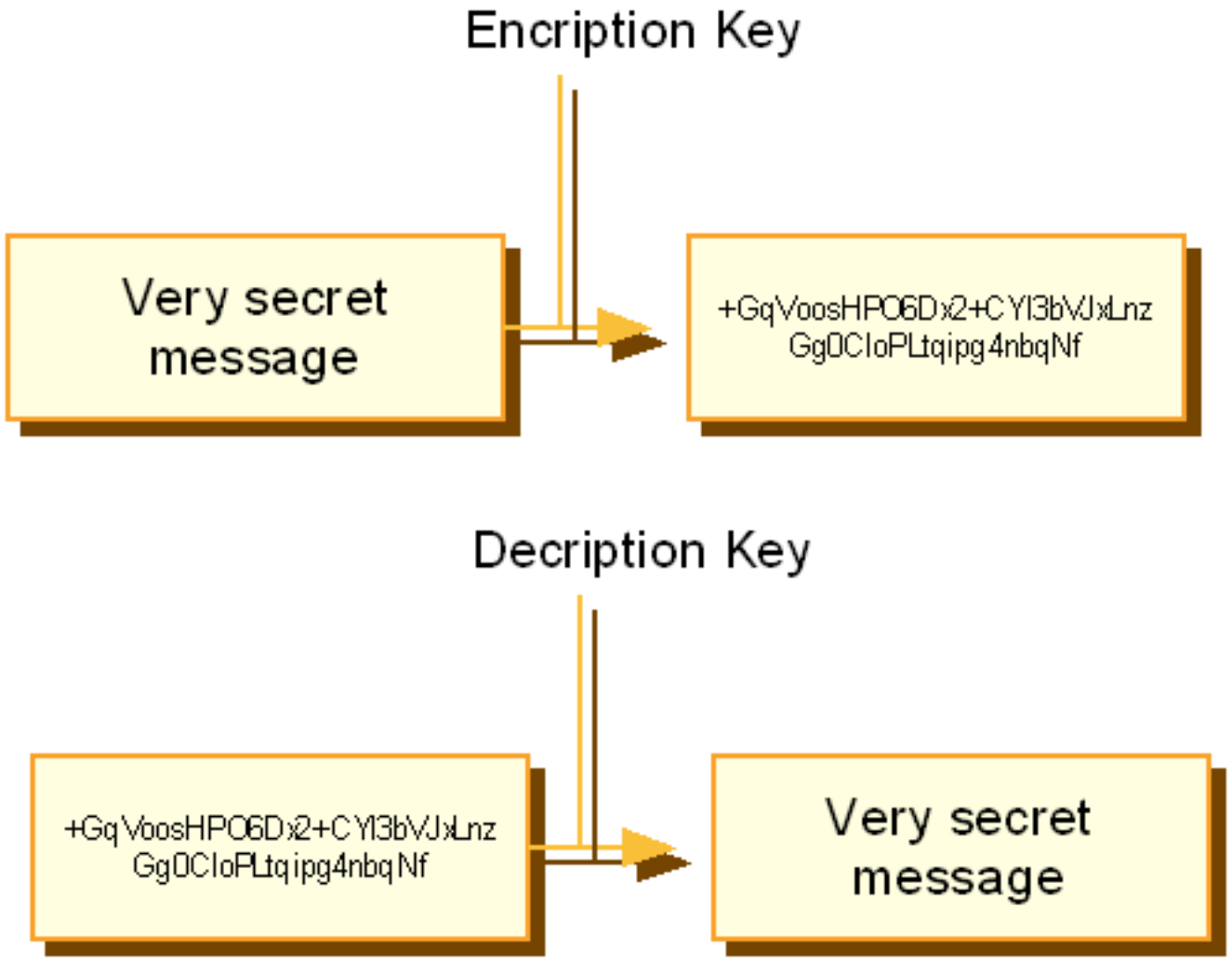
```
<Location /restricted>
Allow from 10.0.0.0/255.255.255.0
Authtype Basic
AuthName "Intranet"
AuthUserFile /usr/local/apache2/conf/htusers
AuthAuthoritative on
require valid-user
Satisfy any
</Location>
```

Secure Server

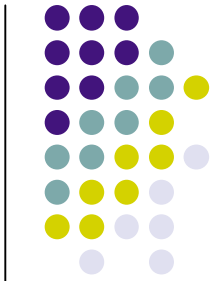


- SSL/TLS family of protocols
  - Confidentiality : encryption
    - Symmetric/asymmetric
  - Integrity : digests
  - Authentication : certificates
- mod_ssl
  - Apache 1.3 thru extensions (require patching the server)
  - Apache 2.0 support built-in

Encryption: Confidentiality

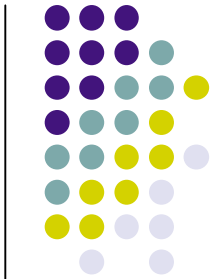


How SSL works



- Client (browser) tries to connect to server
- Handshake: client and server exchange keys and certificates
- Verify certificate validity
- Use each other's public key to securely agree on a symmetric key
- Transmit data using symmetric key

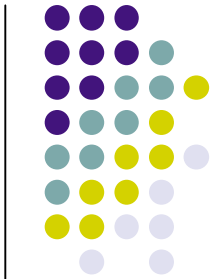
mod_ssl



- Build mod_ssl
- Create keys, certificate, Certificate Signing Request
- Configure Apache (details on PDF article)

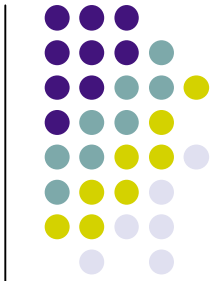
```
Listen 80
Listen 443
<VirtualHost _default_:443>
ServerName www.example.com
SSLEngine on
SSLCertificateFile /path/openssl/certs/www.example.com.cert
SSLCertificateKeyFile /path/openssl/certs/www.example.com.key
</VirtualHost>
```

Server Isolation



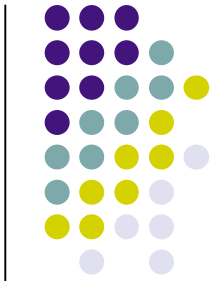
- User/Group directives
- Virtualization:
  - User mode Linux, others
  - chroot environments
- Multiprocessing Modules
  - MPUX
  - per_child MPM
  - mod_become

Server Isolation



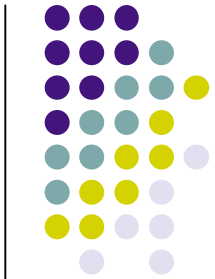
- mod_suExec
- Safe interpreters (PHP, Tcl, others)
  - Restrict specific functionality
  - Protect server from poorly written or malicious scripts

Secure gateway



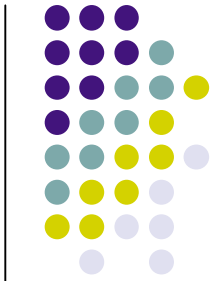
- Apache as a reverse proxy
  - Unified front end
    - Authentication
    - Updates
  - Performance (SSL, latency)
  - HTTP level firewall with rewrite rules

Keeping up to date



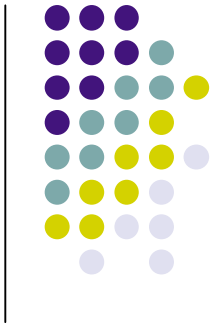
- Apache announce lists
- ApacheWeek
- Vendor package updates
- BugTraq

Related sessions



- MO20: Extending HTTP Authentication
- TU01: Apache authentication
- TU13: Apache Security Secrets Revealed
- TU20: Open Source Web Single Sign On
- WE09: PHP Attacks and Defense

Q&A



Thanks for Attending!

More info:
http://www.apacheworld.org/
PDF article for this session

You can reach me at:
daniel@rawbyte.com

This presenation has ended.
Click anywhere to return.

_

